TEACHING CASE · HEALTHCARE · HIPAA

One stolen password. Two locks.

How a 22-person dental practice can close the same gap behind the Change Healthcare attack for under $6,000, and teach its staff to do it with their own hands.



0 of 40

stolen-password logins got through once MFA was on

9.5 : 1

first-year return on about $5,890 of security spending

62 hrs

of access-review time saved each year by a short script

Anèl Henning · Logical Coders, Tampa, FL

Fictional organization · illustrative data

01 · THE WEAK SPOT

A big breach that started with one login

FEB 2024
Attackers log in to a Change Healthcare remote-access portal with stolen credentials. The portal has no MFA (Witty, 2024).

WEEKS AFTER
Claims and pharmacy payments stall for providers across the U.S.

2025
About 190 million people affected, the largest health breach reported to HHS (HHS OCR, 2025).

THIS CASE
A small practice with the same tools closes the same gap, and tests whether it worked.

22	4	9,800	23	7
EMPLOYEES	TAMPA OFFICES	PATIENT RECORDS	RISKS FOUND	ACCESS PROBLEMS

Most health data breaches do not start with clever code. They start with a person and a password. Verizon found that 68% of breaches involved a human element, like a phishing click or a reused password (Verizon, 2024).

Small practices run the same kinds of tools as large ones: a cloud electronic health record (EHR), a patient portal, and email. They rarely have a security team. The HIPAA Security Rule still requires them to control who can reach patient data and to review that access regularly (Security Standards, 2024).

Sunshine Dental Group is a fictional practice built to show what that looks like. A first review found 23 risks. Three were Critical: ransomware on the EHR, outside access to the patient portal, and lost or stolen phones. A re-run of the access check found seven problems across eight accounts, including a former employee whose account stayed active for 19 days and four active accounts with no MFA.

ABOUT THIS CASE

Sunshine Dental Group is fictional. No real patient or company data is used, and every trial number is illustrative. The real incidents are cited from public sources.

STARTING WITH THE FRONT DESK

We followed the human-centered design cycle in ISO 9241-210: understand the people, define what they need, design, and test with them again (ISO, 2019). Security that slows people down gets worked around. When people break the rules, it is usually because the rules do not fit their work (Adams & Sasse, 1999).

- **Understand.** Interviews showed a shared front-desk login, kept "so the phones never wait."
- **Define.** "A front-desk worker needs to open a chart in under 10 seconds without sharing a password."
- **Design.** A tap-to-sign-in security key on each badge lanyard. MFA adds about two seconds.
- **Test.** Staff timed themselves on a practice account before go-live.

02 · WHAT WE SET OUT TO PROVE

Three hypotheses, three trials

H1 · SECURITY

MFA stops stolen-password logins

Phishing-resistant MFA on the EHR and portal will block logins that use a stolen password (Grassi et al., 2017).

SUPPORTED

H2 · TIME

A script beats a manual review

A monthly automated access review (NIST AC-2) will find more problems in less time than a manual check (Joint Task Force, 2020).

STRONG TREND

H3 · LEARNING

Hands-on training builds confidence

Staff trained with a tactile kit and guided software will feel more capable and report more test phishing emails than staff shown slides.

STRONG TREND

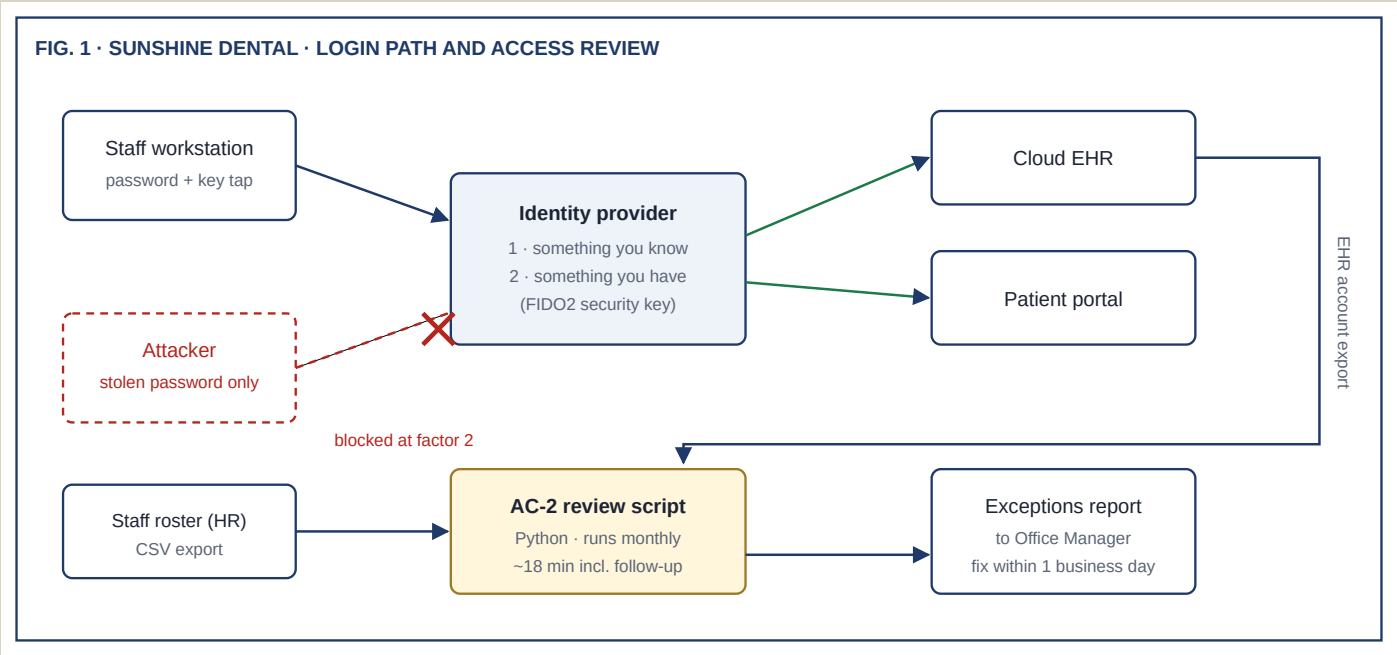


Figure 1. How the solution is built. Every login passes through an identity provider that asks for two factors, so a stolen password alone stops at the second factor. Each month, a short Python script compares the EHR's account list with the HR roster and sends a list of problems to the office manager.

TRIAL A · STOLEN-PASSWORD REPLAY

Two offices got MFA first and two kept passwords only, for six weeks. With the owner's written permission, the IT vendor planted test accounts and tried 40 logins per group with a known "stolen" test password from outside the network.

TRIAL B · ACCESS REVIEW

Seven known problems were planted in a copy of the account list, such as a leaver who was not disabled and a shared login. The office manager reviewed it by hand, and then the script ran on the same list.

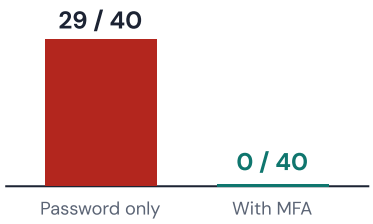
TRIAL C · TRAINING

The 22 staff were split into two groups. One saw a 30-minute slide talk. The other used the Two-Lock Records Box and a software walkthrough. Both groups took a six-item self-efficacy survey before and after (Bandura, 2006). Thirty days later, everyone got the same harmless test phishing email.

03 · WHAT HAPPENED

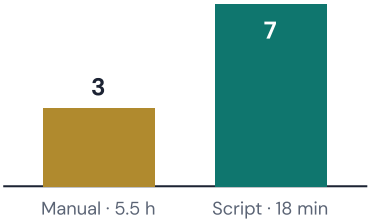
A stolen password was worth nothing

Stolen-password logins that reached patient data



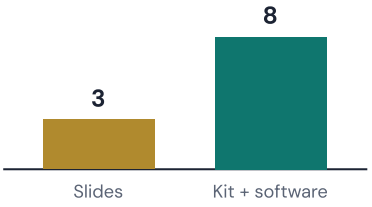
Fisher's exact test, $p < .001$

Planted access problems found (of 7)



Fisher's exact, $p = .070$, a small sample

Reported the test phishing email (of 11)



Fisher's exact, $p = .086$, a small sample

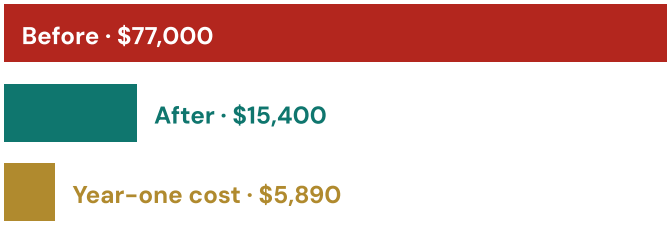
Illustrative data for a fictional practice. Self-efficacy (1–5) rose from 2.4 to 3.9 with the kit, and from 2.5 to 3.0 with slides.

H1 is clearly supported. H2 and H3 show strong trends, but with groups this small they do not reach the usual .05 cutoff. That is an honest result and a useful lesson: an 11-person group can show a real difference without meeting a statistical cutoff. The fix is to repeat the trial across more practices, not to drop the finding.

04 · MONEY AND TIME

Cheaper to build in than to bolt on

EXPECTED YEARLY LOSS (ALE)



ALE = single loss ($385,000) × yearly chance (0.20 → 0.04)

Fixing a problem early costs less than fixing it later (Boehm, 1981). Turning on MFA when a portal is set up takes an afternoon. Turning it on after a breach comes with forensics, legal fees, and closed offices. A smart security budget stays well below the loss it prevents (Gordon & Loeb, 2002).

9.5 : 1

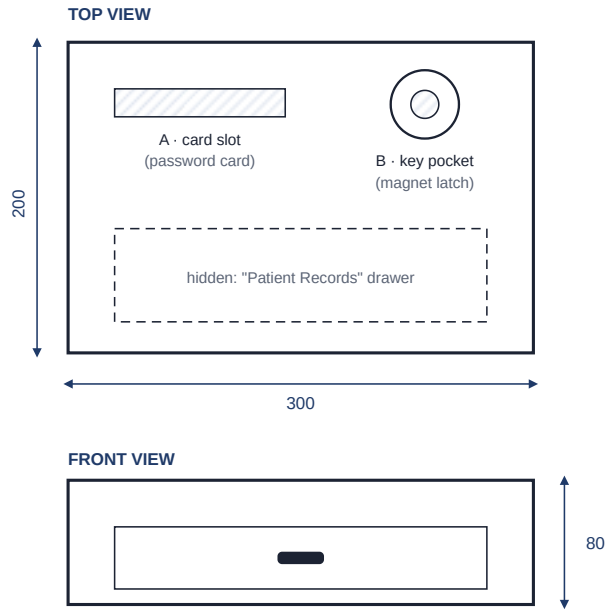
return in year one: $55,710 net benefit on $5,890 spent

Security keys	$1,100
MFA licenses	$1,584
Device management	$1,056
Staff training time	$1,232
Script setup	$750
4 training kits	$168
Total, year one	**$5,890**

Time saved: about 5.2 hours a month, or 62 hours a year, given back to patient care.

A box with two locks makes "two factors" real

FIG. 2 · TWO-LOCK RECORDS BOX · TACTILE MFA TRAINER · ALL DIMS IN MM





BILL OF MATERIALS (PER KIT)

#	Part	Qty	Cost
1	3 mm birch plywood, laser cut	1 sheet	$12
2	Ø20 × 3 mm neodymium magnets	4	$4
3	Spring latch + hinge set	1	$7
4	Printed "password" cards (incl. 1 stolen)	6	$5
5	Token tiles (raised texture, magnet)	6	$8
6	Scenario card deck + QR to walkthrough	1	$6
	Total per kit		**$42**
	Build time ≈ 45 min with a makerspace laser cutter		

Figure 2. How the training kit is made. The drawer opens only when both locks release: the card goes in slot A (something you know), and a magnetic token tile sits in pocket B (something you have). A learner holding only the "stolen" card can feel that the drawer stays shut. Raised textures make the kit usable for learners with low vision. The parts cost $42, and it takes about 45 minutes to build on a makerspace laser cutter.

THE PROBLEM TRAIL: ONE HABIT, FIVE STEPS

1 — Notice
"A login alert says someone signed in from another state."

2 — Guess
"Was it a stolen password?"

3 — Test in software
Scan the QR code. Run the access-review script on a practice file and find the account that should not be active.

SOFTWARE

4 — Prove by hand
Try the stolen card in the box. It fails. Add the tile. It opens.

TACTILE

5 — Report
Press "Report phish" and tell the office manager what you found.

BUILDING SELF-EFFICACY ON PURPOSE

Self-efficacy is a person's belief that they can succeed at a specific task (Bandura, 1977). Staff who believe they can protect data are more likely to follow safe practices (Rhee et al., 2009). The training uses all four of Bandura's sources.

Mastery
Each learner opens the box themselves, failing first and then succeeding.

Seeing others
Pairs take turns, so each person watches a coworker do it first.

Encouragement
Short, specific praise: "You caught that the card was not enough."

Calm body
Low stakes and a little playful, which lowers the stress around "IT."

WHY HANDS-ON LEARNING WORKS

People learn best by doing, reflecting, and trying again (Kolb, 1984). Physical action can anchor abstract ideas (Wilson, 2002). "Two factors" is abstract, and a box with two locks is not. Active methods outperform lectures across many fields (Freeman et al., 2014). The kit is a bridge to the real tool, not a replacement for it: every scenario ends in the actual software. Each scenario card follows the problem trail, so staff learn a habit, not only a fact (Hmelo-Silver, 2004).

"With MFA in place, a stolen password was worth nothing."

TRIAL A · 0 OF 40 REPLAY LOGINS SUCCEEDED

TAKEAWAYS FOR AUDITORS

- Ask which portals still accept a password alone.
- Re-perform the access review yourself instead of asking whether it happened.
- Check that leavers are disabled within one business day.
- Ask to see the training, not only the attendance sheet.

LIMITATIONS

The practice and its data are fictional. Groups of 11 are too small to prove small differences, and a 30-day check cannot show long-term behavior. A real study should cover several practices, randomize by office, and get ethics approval before any test phishing.

CONCLUSION

The Change Healthcare attack shows how much damage one stolen password can do. For a small practice, the fix is not exotic. Turn on MFA from day one, check access every month with a short script, and teach staff with something they can hold. Here that plan costs under $6,000 in its first year, saves about 62 hours of review time, and gives staff the confidence to act.

REFERENCES

Adams, A., & Sasse, M. A. (1999). Users are not the enemy. *Communications of the ACM, 42*(12), 40–46. https://doi.org/10.1145/322796.322806

Bandura, A. (1977). Self-efficacy: Toward a unifying theory of behavioral change. *Psychological Review, 84*(2), 191–215. https://doi.org/10.1037/0033-295X.84.2.191

Bandura, A. (2006). Guide for constructing self-efficacy scales. In F. Pajares & T. Urdan (Eds.), *Self-efficacy beliefs of adolescents* (pp. 307–337). Information Age Publishing.

Boehm, B. W. (1981). *Software engineering economics*. Prentice-Hall.

Freeman, S., Eddy, S. L., McDonough, M., Smith, M. K., Okoroafor, N., Jordt, H., & Wenderoth, M. P. (2014). Active learning increases student performance in science, engineering, and mathematics. *PNAS, 111*(23), 8410–8415. https://doi.org/10.1073/pnas.1319030111

Gordon, L. A., & Loeb, M. P. (2002). The economics of information security investment. *ACM Transactions on Information and System Security, 5*(4), 438–457. https://doi.org/10.1145/581271.581274

Grassi, P. A., et al. (2017). *Digital identity guidelines: Authentication and lifecycle management* (NIST SP 800-63B). https://doi.org/10.6028/NIST.SP.800-63b

Hmelo-Silver, C. E. (2004). Problem-based learning: What and how do students learn? *Educational Psychology Review, 16*(3), 235–266. https://doi.org/10.1023/B:EDPR.0000034022.16470.f3

IBM. (2024). *Cost of a data breach report 2024*. https://www.ibm.com/reports/data-breach

International Organization for Standardization. (2019). *Ergonomics of human-system interaction — Part 210* (ISO 9241-210:2019).

Joint Task Force. (2020). *Security and privacy controls for information systems and organizations* (NIST SP 800-53, Rev. 5). https://doi.org/10.6028/NIST.SP.800-53r5

Kolb, D. A. (1984). *Experiential learning*. Prentice-Hall.

Rhee, H.-S., Kim, C., & Ryu, Y. U. (2009). Self-efficacy in information security. *Computers & Security, 28*(8), 816–826. https://doi.org/10.1016/j.cose.2009.05.008

Security Standards: Administrative Safeguards and Technical Safeguards, 45 C.F.R. §§ 164.308, 164.312 (2024).

U.S. Department of Health and Human Services, Office for Civil Rights. (2025). *Change Healthcare cybersecurity incident frequently asked questions*. https://www.hhs.gov/

Verizon. (2024). *2024 data breach investigations report*. https://www.verizon.com/business/resources/reports/dbir/

Wilson, M. (2002). Six views of embodied cognition. *Psychonomic Bulletin & Review, 9*(4), 625–636. https://doi.org/10.3758/BF03196322

Witty, A. (2024, May 1). *Testimony before the U.S. Senate Committee on Finance*. https://www.finance.senate.gov/